

Individuell inlämningsuppgift

Workshop 2 - MITRE ATT&CK och hotanalys

Syfte

Denna individuella inlämningsuppgift följer upp Workshop 2 och tränar förmågan att använda MITRE ATT&CK, TTP, defensiv hotanalys, attackkedjor, försvarsfrågor, källor, spårbarhet och koppling till projektarbete.

Viktig avgränsning

Uppgifterna ska användas för analys, dokumentation och försvar. Beskriv inte tekniska genomförandesteg för angrepp. Fokusera på vad ett säkerhetsteam behöver förstå, upptäcka, förhindra och följa upp.

Instruktion till studenten

- Uppgiften genomförs individuellt och lämnas in enligt lärarens instruktion i Canvas.
- Uppgiften täcker kursmål 1, 2, 6 och 11.
- Du får använda materialet från Workshop 2, MITRE ATT&CK, kursmaterial och egna anteckningar.
- Du får använda generativa AI-assistenter och AI-assisterade säkerhetsverktyg, dock ska du beskriva eventuell AI-användning och vad som kontrollerats manuellt.
- Fokusera på tydliga resonemang, spårbarhet och defensiv analys.
- Dina svar ska visa att du kan använda begreppen, inte bara återge definitioner.
- Om du är osäker: skriv vad du är osäker på och hur du skulle följa upp det.

Översikt

Del	Fokus	Uppgifter
Del 1	Förstå MITRE ATT&CK som analysramverk	1-4
Del 2	TTP: Tactic, Technique och Procedure	5-8
Del 3	Bygg en defensiv attackkedja	9-12
Del 4	Försvarsfrågor och Blue/Purple-perspektiv	13-16
Del 5	Källor, spårbarhet och kvalitet	17-20
Del 6	Koppling till backlog, sprint och Workshop 3	21-24

Del 1 - Förstå MITRE ATT&CK som analysramverk

Uppgift 1

Beskriv med egna ord vad MITRE ATT&CK används till i ett säkerhetsteam.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på analys, språk, struktur och försvarsperspektiv.

Mitre att&ck används för att på ett strukturerat gemensamt sätt förstå hur en angripare arbetar så som beteende mönster, metoder och mål. Det kan användas till både defensiva syften eller om en attack har skett. Defensivt används det då tex genom att red team testat olika tekniker och då kan blue team jämföra tex logga och larm för att se om något missades eller vad som funkade.

När en attack har skett kan det användas för att strukturera angripares tillvägagångssätt och se över det steg för steg för att hitta vad som gjorde att det inte stoppades eller upptäcktes och därefter hitta vad som behöver åtgärdas så att det kan förbyggas och upptäckas nästa gång.

Det är också ett gemensamt språk som skapar struktur i kommunikationen mellan olika team och ledningen snarare än att alla använder olika egna begrepp, samma information men varje berörd person använder den olika. Det hjälper också till att avgöra vilka åtgärder som bör prioriteras både inom teamet och som ett underlag att visa ledningen för deras prioriteringar av tex budget och personal.

Uppgift 2

Förklara varför ATT&CK inte ska användas som en checklista för att "göra attacker".

Svarsinstruktion: Skriv 150-250 ord. Beskriv skillnaden mellan analysramverk och angreppsinstruktion.

Det ska inte användas som en checklista för att det främst används som ett analytiskt verktyg för att beskriva och förstå angriparen och attackkedjan. En angreppsinstruktion innehåller en annan typ av beskrivning på hur det ska gå till med kommandon och verktyg med tydliga steg för hur man ska ta sig in i systemet.

Det betyder egentligen att att&ck beskriver beteende, mål och metoder i en generell aspekt, vilket innebär att det finns fler än ett sätt att genomföra ett angrepp på även om det är inom samma kategori av teknik eller taktik. Exempelvis så skickar angriparen ett mejl med en skadlig länk, men det skulle också kunna vara en skadlig fil, båda hamnar under samma taktik och teknik men dem utförs på olika sätt, ena är en fil med skadligt innehåll och den andra en länk med en falsk inloggningssida.

Hade det varit en angreppsinstruktion så hade den haft information om exakt vad den skadliga filen innehåller och vad den ska göra men också exakta steg som leder fram till att attacken genomförs.

Uppgift 3

Välj fem tactics från Enterprise Matrix och beskriv vad varje tactic betyder på en övergripande nivå.

Svarsinstruktion: Använd egna ord. Undvik tekniska genomförandedetaljer.

Credential access: Angriparen vill få tag på tex inloggningsuppgifter som kan ge åtkomst.

Initial access: Angriparen försöker hitta första vägen in i ett system.

Persistence: Angriparen vill försöka hålla sig kvar länge i systemet.

Lateral movement: Angriparen vill försöka ta sig vidare inom systemet till andra delar.

Collection: Angriparen samlar information som är intressant för måltavlan.

Uppgift 4

Beskriv hur ATT&CK kan stödja kommunikationen mellan red team, blue team och ledning.

Svarsinstruktion: Skriv 200-300 ord. Ta upp gemensamt språk, spårbarhet och prioritering.

Red team tänker "kan vi göra detta?" Så dem använder det genom att beskriva vilka taktiker och tekniker som provats.

Blue team tänker "hur kan vi upptäcka och stoppa?" Så dem använder det för att förklara vilka beteenden som kan upptäckas och hur försvaret kan förbättras.

Ledningen tänker "hur viktigt är detta?" Dem använder det för att få en generell uppfattning om vad dem är sårbara för eller för att veta hur resurser ska fördelas som vad som bör prioriteras.

Så att &ck kan stödja kommunikationen genom att dem pratar ett gemensamt språk men av olika anledningar utan missförstånd och krångel. Det skulle kunna se ut som så att red team testar olika tekniker och då kan blue team se vad som funkar eller inte i systemet, som tex att något inte larmar eller det finns andra brister som bör fixas och då kan ledningen i sin tur besluta om hur tid och resurser ska prioriteras.

När det gäller spårbarheten så kan det användas för att se vad som testats, vad som funkade eller inte funkade och se vad som bör följas upp senare. Kort och gott är det ett sätt för alla parter att jobba mot samma mål även om dem använder informationen olika.

Del 2 - TTP: Tactic, Technique och Procedure

Uppgift 5

Förklara skillnaden mellan tactic, technique och procedure.

Svarsinstruktion: Använd ett eget defensivt exempel. Håll dig på konceptuell nivå.

Tactic: vad är målet

Technique: vad är metoden

Procedure: hur genomfördes det

Exempelvis så vill en angripare komma åt en inloggning (tactic), angriparen använder sig av phishing (technique) så angriparen skickar ut mejl som ser ut att komma från en betrodd användare med skadlig länk (procedure).

Uppgift 6

Skapa en TTP-förklaring för tre valfria ATT&CK-tekniker.

Svarsinstruktion: För varje teknik: skriv tactic, technique och en kort procedure-beskrivning utan operativa instruktioner.

Tactic: lateral movement, technique: taint shared content, procedure: angriparen lägger in ett skadligt dokument i det gemensamma lagringsutrymmet som ger angriparen möjlighet att sprida sig vidare i andra delar av organisationen hos användare som öppnar dokumentet.

Tactic: collection, technique: browsersession hijacking, procedure: angripare hijackar en aktiv webbsession och får tillgång till den aktiva sessionen och samlar relevant data.

Tactic: impact, technique: network denial of service, procedure: angripare skickar massor av förfrågningar samtidigt så ingen vanlig användare kan komma åt tjänsten.

Uppgift 7

Välj en tactic och identifiera tre tekniker som kan höra hemma inom den.

Svarsinstruktion: Motivera varför teknikerna passar in i tactiven.

Tactic: impact

Technique: network denial of service, för att det gör tjänsten otillgänglig genom att överbelasta den.

Technique: data destruction, för att angriparen förstör data i syfte att påverka verksamheten negativt.

Technique: data encrypted for impact, för att det gör att data blir oåtkomlig för verksamheten.

Alla dessa hör hemma under den kategorin för att det gör stor negativ påverkan för berörda parter, både användare och verksamheter eftersom det stör, förstör och gör det oåtkomligt.

Uppgift 8

Beskriv varför det kan vara svårt att mappa en observation till rätt teknik.

Svarsinstruktion: Ta upp osäkerhet, kontext, datakvalitet och behov av källor.

En ensam observation har kanske inte tillräckligt med kontext för att kunna bedömas, man behöver kanske se över vad som hände före eller efter observationen men också vilken användare eller på vilket system som observationen gjordes på för att minska osäkerheten. Man behöver samla denna data för att få mer information att kunna jämföra med. Saknas det dessutom kvalitet på data som loggar etc blir det också svårt att få tillräckligt med information för att kunna göra en korrekt bedömning. Det man kan göra är att kontrollera och jämföra andra rapporter och analyser för att se vad man mer kan kolla efter eller göra en mer korrekt bedömning.

Del 3 - Bygg en defensiv attackkedja

Uppgift 9

Bygg en enkel attackkedja med 3-5 steg.

Svarsinstruktion: Använd tactics som etiketter. Syftet är analys och försvar, inte teknisk genomförandeinstruktion.

1. Initial access, få första åtkomsten
2. Persistence, hålla sig kvar
3. Lateral movement, röra sig vidare
4. Collection, samla relevant information
5. Impact, påverkan på verksamheten

Uppgift 10

Beskriv varje steg i er kedja med “varför”, “hur” och “vad såg vi?”.

Svarsinstruktion: Koppla till TTP-modellen: tactic, technique och procedure.

1. Tactic: Få åtkomst till systemet
Technique: Phishing
Procedure: Angriparen skickade ett mejl med falsk inloggningssida
2. Tactic: Hålla sig kvar i systemet
Technique: Account manipulation: device registration
Procedure: Angriparen registrerar sin enhet på det hijackade kontot för att kringgå eller uppfylla MFA krav och därmed behåller sin åtkomst till systemet
3. Tactic: Röra sig vidare till andra delar av systemet
Technique: Taint shared content
Procedure: Angriparen delar en skadlig fil i den gemensamma lagringen som ger åtkomst till de konton vars användare öppnar den
4. Tactic: Samla relevant information
Technique: Data from information repositories
Procedure: Angriparen hittade och kom åt vad som var värdefullt för verksamheten
5. Tactic: Göra data otillgänglig för ekonomisk vinning
Technique: Data encrypted for impact
Procedure: Angriparen använde det som var värdefullt från steg 4 för att veta precis vad den skulle kryptera och begär nu en summa pengar för att avkryptera det igen

Uppgift 11

Identifiera vilka steg i attackkedjan som är mest osäkra.

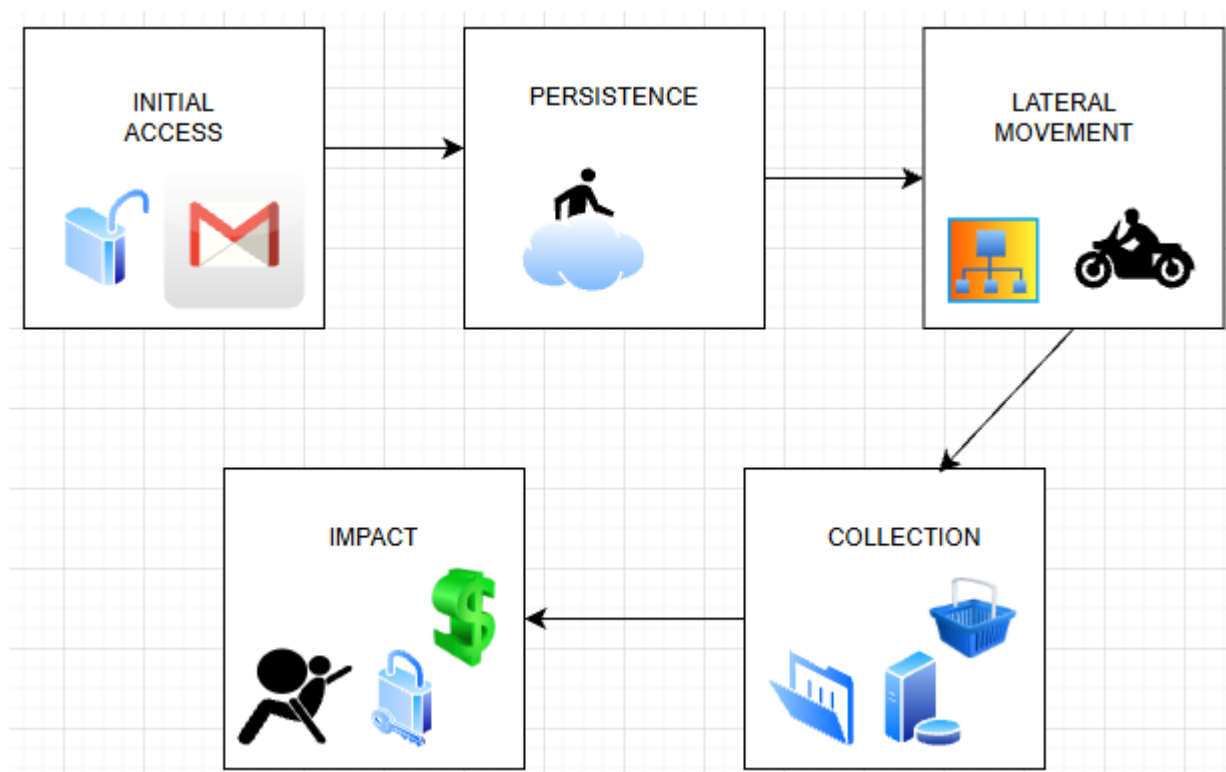
Svarsinstruktion: Beskriv vad ni behöver veta mer om för att göra analysen bättre.

Det jag hade behövt veta är hur loggar set ut för att verifiera vilka system/användare som är påverkade och verifiera om en ny enhet faktiskt har registrerats på de hijackade kontona eller inte. Jag vill ha loggar och mer information vad som hänt före och efter vare observation. Vem öppnade de skadliga dokumentet? Vilka filer, databaser eller annan information fick angriparen tillgång till? Utan rätt information är det egentligen osäkert hur angriparen hållit sig kvar i systemet och hur vida angriparen faktiskt har kunnat röra sig lateralt och vart den kunnat röra sig och om den fått tillgång till mer än vad den använt i sitt slutmål som är impact.

Uppgift 12

Rita eller beskriv attackkedjan som en enkel kedja från första kontakt till påverkan.

Svarsinstruktion: Använd pilar och korta rubriker. Om ni skriver digitalt kan ni använda tabell eller punktlista.



Del 4 - Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Formulera minst en försvarsfråga per steg i attackkedjan.

Svarsinstruktion: Exempel: Hur skulle detta kunna upptäckas? Vilken signal, rutin eller kontroll kan vara relevant?

1. Utbilda personalen i phishing och försöka ha något typ av filter eller varning vid länkar.
2. Ha ett varningssystem för nya registrerade enheter och ett extra verifieringssteg vid registrering av ny enhet.
3. Att scanna filer och ha larm för ovanliga eller misstänkta filändringar.
4. Larm för ovanligt åtkomstmönster.

5. Ha backup så att det som blivit krypterat inte går förlorat.

Generellt att ha bra relevanta larm, regelbunden kontroll och att allt loggas ordentligt.

Uppgift 14

Välj två tekniker och resonera kring möjliga detektionssignaler.

Svarsinstruktion: Håll svaret på konceptuell nivå. Beskriv typer av signaler, inte tekniska exploit-steg.

1. Account manipulation: device registration
Möjlig detektionssignaler skulle kunna vara att en ny enhet registreras från en ovanlig plats, på en ovanlig tid eller i samband med en annan misstänkt händelse.
2. Taint shared content
Här skulle det kunna vara att en fil läggs till eller ändras utanför användarens normala beteendemönster, som avvikande tider, en mapp användaren normalt sätt inte brukar använda eller i ett okänt format. Det skulle också kunna vara att flera användare som öppnar samma fil triggar liknande säkerhetslarm eller får ovanlig aktivitet på sina konton eller system efteråt.

Uppgift 15

Välj två tekniker och resonera kring möjliga riskreducerande åtgärder.

Svarsinstruktion: Beskriv organisatoriska, tekniska eller processmässiga åtgärder.

1. Account manipulation: device registration: Att reducera risken för en sån här typ av teknik kan man begränsa vem som faktisk kan lägga till en ny enhet men också sätta standarder på vad för typ av krav enheten ska uppfylla för att kunna registreras. Samtidigt bör man också ha en varning som flaggas när nya eller okända enheter registreras.
2. Data encrypted for impact: Att reducera konsekvensen efter en sån här typ av attack så bör man regelbundet säkerhetskopiera och förvara det i en separat miljö så att man kan återställa. Man bör också ha en färdig plan för hur man hanterar en sån incident så man kan isolera det drabbade systemet och undvika ytterligare problem.
Att reducera risken för att det ska kunna hända bör man begränsa åtkomstbehörigheten efter principen least privilege.

Uppgift 16

Beskriv hur ett säkerhetsteam kan använda en attackkedja för att förbättra sitt försvar.

Svarsinstruktion: Skriv 200-300 ord. Ta upp lärande, prioritering och uppföljning.

Först och främst får teamet en tydlig samlad överblick över hur attacken gick till från början till slut och kan då förstå vad som hände.

Eftersom attackkedjan är uppdelad i olika faser så är det lättare att se lite mer exakt vart de svaga länkarna i systemet finns men också vart systemet är som starkast och vad som funkar på ett strukturerat sätt.

Det ger i sin tur teamet en möjlighet att gå igenom allt steg för steg och kolla vad som behöver förbättras, tex om angriparen tog sig in genom phishing så kan dem undersöka vad som var svagast, om det var att personalen behöver bättre utbildning i ämnet eller om det saknas varningar för suspekta mejl eller om det ens finns ett varningssystem för det från början.

Med informationen från attackkedjan kan dem också jämföra varje del med tex loggar eller larm för att se om det var något som borde larmat som inte gjort det eller något i loggarna som borde flaggats som inte gjorde det, men också kanske se ett samband på en observation eller händelse som kunde ha varit avgörande för att upptäcka attacken i ett tidigare stadie.

Den hjälper också till att underlätta för teamet vad de behöver prioritera att åtgärda först eftersom allt inte kan fixas på en och samma gång. När det gäller uppföljning så kan attackkedjan användas för att i efterhand, när brister eller risker blivit åtgärdade, kontrollera om det har skett en förbättring i att upptäcka, förebygga eller begränsa en liknande attack igen.

Del 5 - Källor, spårbarhet och kvalitet

Uppgift 17

Dokumentera vilka källor ni använder i er ATT&CK-analys.

Svarsinstruktion: Skriv minst tre källor eller länkar. Beskriv kort vad varje källa bidrar med.

<https://attack.mitre.org/matrices/enterprise/> : mitre att&ck ger en överblick över beteende mönster och tillvägagångssätt av angripare.

<https://www.cisecurity.org/controls> : CIS controls är samlat best practice guidelines för att skydda sig mot vanliga cyberhot.

<https://www.nis-2-directive.com/> : NIS2 är grundkrav på säkerhet och incidenthantering på EU nivå.

Uppgift 18

Beskriv hur ni säkerställer att er TTP-mappning är rimlig.

Svarsinstruktion: Ta upp källa, motivering, osäkerhet och gruppgranskning.

Jämföra observationen och omständigheterna runt det med tex mitre att&ck och jämföra med andra rapporter och analyser för att bedöma sannolikhet och klara upp eventuella osäkerheter. Kolla över om det är rimligt att tekniken eller taktiken är rimlig att genomföra i systemet men också låta flera i teamet komma med andra synvinklar och tankar om det.

Uppgift 19

Skapa en mini-Definition of Done för en färdig hotanalys.

Svarsinstruktion: Lista minst fem kriterier. Kriterierna ska gå att använda av hela gruppen.

1. Hoten är tydligt beskrivna.
2. Relevant TTP är gjort kopplad till mitre att&ack.
3. Observationer och antaganden är tydligt separerad från fakta.
4. Potentiella risker och konsekvenser är listade.
5. Källor som använts i analysen är listade.
6. Rekommenderad försvarsåtgärder finns beskrivet.
7. Analysen har granskats av åtminstone en annan team medlem.

Uppgift 20

Beskriv vad som gör en hotanalys användbar för någon annan än den som skrev den.

Svarsinstruktion: Skriv 150-250 ord. Fokusera på tydlighet, spårbarhet och mottagare.

Hotanalysen blir användbar när den är skriven på ett sätt så att mottagaren kan förstå och dra nytta av den information som beskrivits. Ett exempel kan vara att säkerhetsteam vill ha mer detaljer om taktik, teknik, och loggar medan ledningen vill ha information om vilka risker och hot som finns så dem förstår hur allvarliga dem är och kan prioritera tex resurs och budget runt det.

Den är också användbar om den är tydlig med ett enkelt språk och har bra struktur som gör det lätt att följa hur hoten, riskerna eller observationerna har analyserats.

Dessutom är det användbart om det lätt går att förstå vilka observationer, loggar, rapporter och källor som analysen bygger på så att det är tydligt att informationen stödjer bedömningen. Det bör också framgå tydligt vad som är fakta och vad som är osäker information eller spekulation för att undvika missförstånd. Det gör de lättare för mottagaren att på ett tryggt sätt kunna avgöra nästa steg.

Del 6 - Koppling till backlog, sprint och Workshop 3

Uppgift 21

Uppdatera er backlog baserat på det ni upptäckte i Workshop 2.

Svarsinstruktion: Skriv minst fem nya eller ändrade backlog items. Ge kort motivering.

1. Dela backlog om inventering i två: lista organisationens tillgångar och sammanställ en lista på godkända mjukvaror har olika prioritering och bör därför vara separata.
2. Utöka vår definition of done: fler punkter ger mer tydlighet.
3. Skapad en checklista inför workshop 3: bra med struktur.
4. Lagt till att planera nästa steg: det är bra att kunna planera hur arbetet ska läggas upp.
5. Skapa en TTP tabell: förberedelse inför nästa projekt.

Uppgift 22

Beskriv hur er attackkedja förhåller sig till ert Sprint Goal.

Svarsinstruktion: Är sprintmålet fortfarande relevant? Behöver något justeras?

Vår sprint goal fokuserade framförallt på att bygga upp vårt team och skapa ett tydligt arbetssätt och struktur och kommer att behöva justeras med addering anpassat till nästa projekt.

Uppgift 23

Formulera minst två uppföljningsfrågor inför Workshop 3.

Svarsinstruktion: Frågorna ska kunna användas vid review eller retrospektiv.

Har vi nått vårt mål?

Om inte, varför? Om ja, vad gick bra?

Har vårt arbetssätt funkat eller måste vi ändra något?

Uppgift 24

Förbered en kort statusrapport till Workshop 3.

Svarsinstruktion: Skriv 5-7 punkter: vad ni gjorde, vad som blev klart, vad som är oklart och vad ni vill ändra.

1. Vi uppdaterade vår backlog.
2. Vi hade gärna fått en demonstration på det agila arbetet så vi behöver ställa flerfrågor.
3. Vi har regelbundna möten som vi känner oss nöjda och som funkar bra.
4. Vi har skapat checklistor.
5. Vi planerar våra möten bra och skriver våra protokoll som vi ska.

Frivillig fördjupningsutmaning

Skapa en komplett mini-hotanalys baserad på din Workshop 2-kedja.

Inkludera: mål med analysen, attackkedja, TTP-tabell, försvarsfrågor, källor, osäkerheter, uppdaterad backlog och förslag till nästa sprint. Max tre sidor.

Rekommenderade referenser

- MITRE ATT&CK: <https://attack.mitre.org/>
- MITRE ATT&CK Enterprise Matrix: <https://attack.mitre.org/matrices/enterprise/>
- CISA - Best Practices for MITRE ATT&CK Mapping: <https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>
- MITRE ATT&CK Data & Tools: <https://attack.mitre.org/resources/attack-data-and-tools/>

Bedömningskriterier

Bedömningen fokuserar på analysförmåga, begreppsanvändning, spårbarhet, defensivt perspektiv och koppling till projektarbete.

Matrisen är formulerad med kursens nivåer Godkänt (G) och Väl godkänt (VG). Den mellersta kolumnen beskriver kvaliteter som stärker bedömningen inom godkänd nivå och kan användas som stöd i återkoppling.

Bedömningsområde	Grundläggande krav för G	Tydliga kvalitetskännetecken	Kvalitetskännetecken för VG
Förståelse för MITRE ATT&CK	Kan beskriva ATT&CK på en grundläggande nivå och visar förståelse för ramverkets syfte.	Förklarar ATT&CK med egna ord och kopplar ramverket till hotanalys och säkerhetsarbete.	Visar fördjupad förståelse för ATT&CK som analysramverk och resonerar kring styrkor, begränsningar och användningsområden.
TTP-förståelse	Kan identifiera tactic, technique och procedure samt beskriva skillnaden översiktligt.	Använder TTP-begreppen konsekvent och förklarar sambanden mellan dem.	Använder TTP som ett naturligt analysverktyg och kan motivera val samt alternativa tolkningar.
Attackkedjor	Har skapat en enkel attackkedja där stegen följer en logisk ordning.	Attackkedjan är väl motiverad och sambanden mellan stegen förklaras.	Analysen visar systemsyn och används för att resonera kring risker och försvarsperspektiv.
Försvarsfrågor	Har formulerat relevanta försvarsfrågor.	Försvarsfrågorna är välformulerade och kopplas till upptäckt, begränsning eller uppföljning.	Kopplar angriparbeteenden till flera möjliga försvarsperspektiv och resonerar kring prioritering.
Källor och spårbarhet	Anger källor och referenser till analysunderlaget.	Motiverar hur källorna används och visar förståelse för spårbarhet.	Reflekterar kring källornas styrkor och begränsningar och håller hög dokumentationskvalitet.
Projektarbete	Har uppdaterat backlog eller projektunderlag.	Kopplar analysen till Sprint Goal, backlog eller Definition of Done.	Visar hur analysen skapar värde i projektet och resonerar kring prioritering, risk och nästa steg.

Samlad bedömning

Godkänt (G)

Studenten har genomfört huvuddelen av uppgifterna, visar grundläggande förståelse för ATT&CK, kan beskriva en enkel attackkedja, kan formulera relevanta försvarsfrågor och kan dokumentera sitt arbete.

Väl Godkänt (VG)

Studenten visar god analytisk förmåga, använder ATT&CK och TTP konsekvent, motiverar sina slutsatser, identifierar osäkerheter, visar god förståelse för försvarsperspektivet och kopplar analysen till projektets mål och arbetssätt.